

The MITRE ATT&CK Playbook

A complete, detailed guide to the ATT&CK framework — tactics, techniques, detection engineering, and threat-informed defense

From the matrix structure to real detection rules, this playbook builds the shared vocabulary and practical workflow that connects red team, blue team, and threat intelligence around the same adversary behavior.

Author: Swastik Sagar
Final-year Computer Science Undergraduate
SOC Analyst Intern

August 3, 2026

Preface

Every playbook in this series so far has covered a tool: Nmap for reconnaissance, Wireshark for packet analysis, Splunk and Wazuh for log correlation. MITRE ATT&CK is different — it's not a tool at all, it's a shared vocabulary. It gives every one of those tools a common language to describe *what an adversary is actually doing*, independent of which product happens to detect it.

That shared vocabulary is what makes ATT&CK so useful in practice. A red teamer executing a technique, a detection engineer writing a Splunk correlation rule, and a threat intel analyst reading a vendor report about a new campaign can all point at the same technique ID and know they're talking about the same adversary behavior. This playbook covers the framework's structure first, then how it's actually used — detection engineering, purple teaming, threat intel mapping, and closing the loop with the tools covered earlier in this series.

What this book covers

- The ATT&CK matrix structure: tactics, techniques, and sub-techniques
- The 14 Enterprise tactics, what each one means, and how they chain together
- Reading and interpreting technique pages, data sources, and mitigations
- Groups, software, and campaigns — how threat intel maps onto ATT&CK
- Using ATT&CK for detection engineering and coverage assessment
- Purple teaming with ATT&CK as the shared reference point
- The ATT&CK Navigator and building a heat map of your own coverage
- Mapping Nmap, Wireshark, and SIEM detections to specific techniques
- Walkthroughs of common, high-value techniques analysts see constantly
- Building a threat-informed detection roadmap from ATT&CK

Swastik Sagar

Contents

Preface	i
1 Introduction to MITRE ATT&CK	1
1.1 What ATT&CK actually is	1
1.2 Why it displaced the traditional kill chain	1
1.3 The three ATT&CK matrices	1
1.4 Core terminology	2
2 The ATT&CK Matrix Structure	3
2.1 Reading the matrix	3
2.2 Techniques vs. sub-techniques	3
2.3 Technique IDs	3
3 The 14 Enterprise Tactics	4
3.1 Overview	4
3.2 Reconnaissance and Resource Development	4
3.3 Initial Access	4
3.4 Execution through Impact	5
4 Techniques and Sub-techniques in Depth	6
4.1 Anatomy of a technique page	6
4.2 A worked example: T1059 Command and Scripting Interpreter	6
4.3 High-value techniques worth knowing by ID	7
5 Data Sources and Detection	8
5.1 Data sources in ATT&CK	8
5.2 Detections vs. mitigations	8
6 Groups, Software, and Campaigns	9
6.1 Groups	9
6.2 Software	9
6.3 Why this matters for prioritization	9

7	Using ATT&CK for Detection Engineering	10
7.1	The threat-informed detection loop	10
7.2	From a technique to a real SPL search	10
7.3	Coverage assessment	10
8	Purple Teaming with ATT&CK	11
8.1	What purple teaming adds	11
8.2	A basic purple team workflow	11
8.3	Why this pairs naturally with Nmap and Wireshark	11
9	The ATT&CK Navigator	12
9.1	What Navigator is	12
9.2	Common Navigator layers	12
10	Mapping Tools to ATT&CK	13
10.1	Nmap and reconnaissance/discovery techniques	13
10.2	Wireshark and detection	13
10.3	SIEM (Splunk/Wazuh) and broad coverage	13
11	Common Technique Walkthroughs	14
11.1	T1566 Phishing	14
11.2	T1055 Process Injection	14
11.3	T1078 Valid Accounts	14
11.4	T1486 Data Encrypted for Impact	14
12	Building a Threat-Informed Detection Roadmap	15
12.1	A practical prioritization approach	15
12.2	A repeatable quarterly cycle	15

Introduction to MITRE ATT&CK

1.1 What ATT&CK actually is

ATT&CK (Adversarial Tactics, Techniques, and Common Knowledge) is a publicly available, continuously updated knowledge base of adversary behavior, built by MITRE from real-world observed intrusions. It is not a tool, a product, or a checklist — it is a structured catalog answering one question, over and over, at every stage of an intrusion: *what is the adversary trying to accomplish, and how do they typically do it?*

1.2 Why it displaced the traditional kill chain

The Lockheed Martin Cyber Kill Chain was the dominant model before ATT&CK and is still widely referenced, but it describes an intrusion at a coarse, linear, seven-stage level. ATT&CK is deliberately non-linear and far more granular — an adversary can jump between tactics, revisit earlier ones, and use dozens of distinct techniques within a single kill-chain stage. ATT&CK captures that reality instead of forcing it into a straight line.

Kill Chain	ATT&CK equivalent
7 fixed, linear stages	14 tactics, freely revisited and combined
Describes a campaign at a high level	Catalogs hundreds of specific, granular techniques
Limited detail on execution	Each technique documents real procedures, data sources, and mitigations

1.3 The three ATT&CK matrices

- **Enterprise** — Windows, macOS, Linux, cloud, containers, network, and identity; the matrix this book focuses on
- **Mobile** — techniques specific to Android and iOS
- **ICS** — techniques specific to industrial control systems

1.4 Core terminology

Term	Meaning
Tactic	The adversary's goal at a given stage — the "why" (e.g. Persistence)
Technique	A specific method used to achieve that goal — the "how" (e.g. Scheduled Task/Job)
Sub-technique	A more specific variant of a technique (e.g. Scheduled Task specifically, vs. at/cron)
Procedure	The exact implementation a specific adversary or tool used

A concrete example, top to bottom

Tactic: Persistence. Technique: T1053 Scheduled Task/Job. Sub-technique: T1053.005 Scheduled Task (the Windows-specific variant). Procedure: a specific malware family creating a scheduled task named to blend in with legitimate Windows tasks.

The ATT&CK Matrix Structure

2.1 Reading the matrix

The Enterprise matrix is laid out as columns of tactics, left to right in roughly the order an intrusion tends to progress, with each column listing the techniques that serve that tactic underneath it.

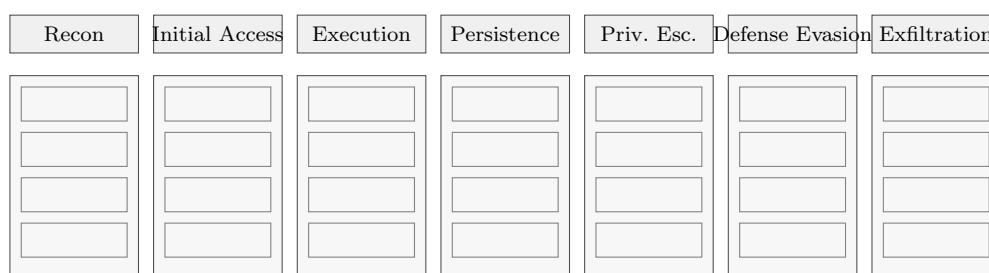


Figure 2.1. *The matrix shape: tactics as column headers, techniques listed underneath each one.*

2.2 Techniques vs. sub-techniques

Most techniques have one or more sub-techniques representing specific implementations. T1548 Abuse Elevation Control Mechanism, for example, has sub-techniques for Setuid/Setgid, Bypass User Account Control, Sudo and Sudo Caching, and more — the parent technique captures the general concept, sub-techniques capture the platform-specific mechanics.

2.3 Technique IDs

Format	Meaning
T1059	A technique ID; Txxxx numbering, assigned once and never reused
T1059.001	A sub-technique ID; the parent technique number plus a three-digit suffix

Every technique page lists applicable platforms, associated data sources, known groups and software observed using it, and recommended mitigations and detections — it is a reference page, not just a label.

3

The 14 Enterprise Tactics

3.1 Overview

Tactic	Adversary's goal
Reconnaissance	Gather information to plan future operations
Resource Development	Establish infrastructure and capabilities to support operations
Initial Access	Get an initial foothold inside the network
Execution	Run adversary-controlled code on a system
Persistence	Maintain access across restarts, credential changes, and other interruptions
Privilege Escalation	Gain higher-level permissions
Defense Evasion	Avoid being detected
Credential Access	Steal account names and passwords
Discovery	Learn about the environment
Lateral Movement	Move through the environment to other systems
Collection	Gather data of interest to the adversary's goal
Command and Control	Communicate with compromised systems to control them
Exfiltration	Steal data out of the network
Impact	Manipulate, interrupt, or destroy systems and data

Tactics aren't sequential

An intrusion routinely revisits earlier tactics — Discovery and Credential Access in particular tend to recur throughout, feeding each subsequent stage of Lateral Movement and Privilege Escalation as the adversary learns more about the environment.

3.2 Reconnaissance and Resource Development

These two tactics cover everything an adversary does before ever touching the target network — OSINT gathering, scanning, phishing infrastructure setup, and acquiring or compromising accounts, domains, and servers to launch the operation from. They're the least visible tactics to a defender, since almost none of it happens on monitored infrastructure.

3.3 Initial Access

- Phishing (T1566) — by far the most common initial access vector observed across real intrusions
- Exploiting a public-facing application (T1190)
- Valid Accounts (T1078) — using legitimately obtained or purchased credentials

- External Remote Services (T1133) — VPNs, RDP, and similar exposed access points

3.4 Execution through Impact

The remaining tactics — Execution, Persistence, Privilege Escalation, Defense Evasion, Credential Access, Discovery, Lateral Movement, Collection, Command and Control, Exfiltration, and Impact — make up the bulk of what happens once an adversary has a foothold, and are covered in technique-level detail throughout the rest of this book.

Techniques and Sub-techniques in Depth

4.1 Anatomy of a technique page

- **ID and name** — e.g. T1059 Command and Scripting Interpreter
- **Description** — what the technique is and why adversaries use it
- **Sub-techniques** — specific implementations (PowerShell, Bash, Python, etc.)
- **Platforms** — which OS/environment the technique applies to
- **Data Sources** — what telemetry could reveal this technique in use
- **Mitigations** — preventive controls that reduce exposure
- **Detection** — what to look for to catch it happening
- **Procedure examples** — specific real-world groups/malware observed using it

4.2 A worked example: T1059 Command and Scripting Interpreter

Sub-technique	Interpreter
T1059.001	PowerShell
T1059.003	Windows Command Shell
T1059.004	Unix Shell
T1059.006	Python
T1059.007	JavaScript

This single technique covers an enormous share of real-world execution — almost every post-exploitation framework and most malware families use one or more of these interpreters to run their actual commands.

4.3 High-value techniques worth knowing by ID

ID	Name	Why it matters
T1055	Process Injection	Extremely common defense evasion method, hides malicious code inside a legitimate process
T1078	Valid Accounts	Abuses real credentials, making activity look legitimate by default
T1003	OS Credential Dumping	Covers LSASS dumping and similar — a common pivot point toward domain compromise
T1021	Remote Services	RDP, SSH, WinRM — how adversaries move laterally using built-in tooling
T1071	Application Layer Protocol	C2 disguised as normal HTTP/HTTPS/DNS traffic
T1486	Data Encrypted for Impact	The technique ID directly behind most ransomware's final stage

Data Sources and Detection

5.1 Data sources in ATT&CK

Each technique page lists the data sources capable of revealing it — these map directly to log types covered earlier in this series: process creation logs, network traffic, Windows Registry, file monitoring, authentication logs, and more.

Data Source	Where it comes from
Process creation	Sysmon Event ID 1, Windows Security 4688
Network traffic	Wireshark/tshark captures, firewall/proxy logs, NetFlow
Command execution	Shell history, PowerShell logging, EDR telemetry
File monitoring	File Integrity Monitoring (e.g. Wazuh syscheck), Sysmon Event ID 11
Authentication logs	Windows 4624/4625, Linux auth.log, SSO/IdP logs
Registry	Sysmon Event ID 12/13/14, EDR registry monitoring

Closing the loop with earlier playbooks

This is exactly where Wireshark and the SIEM playbooks connect back to ATT&CK: a Splunk detection built for T1071 (C2 over an application-layer protocol) is, underneath, a search over the same network data source covered in the Wireshark Playbook's beaconing chapter — ATT&CK just gives that detection a formal name and a place in the bigger picture.

5.2 Detections vs. mitigations

- **Mitigations** are preventive — reduce the chance a technique succeeds at all (e.g. disabling unnecessary scripting interpreters)
- **Detections** are reactive — catch the technique being used despite prevention (e.g. alerting on unusual PowerShell command-line arguments)
- A mature program needs both; ATT&CK documents each separately on every technique page for exactly this reason

Groups, Software, and Campaigns

6.1 Groups

ATT&CK catalogs named adversary groups (e.g. APT29, FIN7, Lazarus Group) tracked across the security industry, each with a profile of the specific techniques they've been observed using — built from public threat intel reporting, not MITRE's own attribution.

6.2 Software

Every piece of malware or tooling ATT&CK tracks — both adversary-custom malware and dual-use tools like Mimikatz or Cobalt Strike — has its own page listing which techniques it implements, letting an analyst go tool-first ("what does this malware family actually do?") instead of only technique-first.

Entity type	Answers the question
Group	Which techniques does this specific threat actor tend to use?
Software	Which techniques does this specific tool/malware implement?
Campaign	Which techniques were used in this specific, time-bound operation?

6.3 Why this matters for prioritization

- If threat intel indicates a group targeting your sector, their ATT&CK group profile becomes a direct, prioritized detection checklist
- Software pages let you pre-build detections for a tool the moment it's reported, without waiting for an incident to force the issue
- Campaigns let you track how techniques evolve within a single adversary's operation over time

Using ATT&CK for Detection Engineering

7.1 The threat-informed detection loop

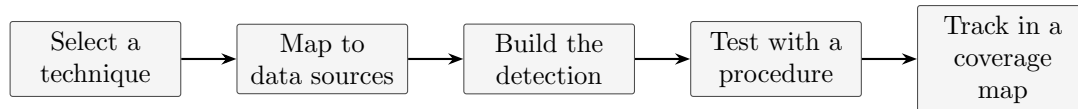


Figure 7.1. *Building detections technique-by-technique, rather than alert-by-alert, is what makes coverage measurable.*

7.2 From a technique to a real SPL search

Revisiting T1053.005 (Scheduled Task) from Chapter 1, mapped onto the SIEM Playbook's Splunk chapter:

Detecting suspicious scheduled task creation

```
index=endpoint sourcetype=sysmon EventCode=1 process_name="schtasks.exe" | where
match(process, "(?i)/create") | stats count by host, user, process
```

This single search is a direct, working implementation of an ATT&CK technique — the ID and technique page are what make it discoverable, comparable across teams, and mappable to a specific line in a coverage matrix rather than just an ad-hoc rule with no larger context.

7.3 Coverage assessment

A coverage assessment scores, per technique, whether a detection exists, how confident it is, and how well-tested it's been — typically visualized directly on the ATT&CK matrix as a heat map (covered further in Chapter 9).

Coverage level	Meaning
None	No detection exists for this technique at all
Partial	Some visibility exists, but the detection is unreliable or narrow
Good	A tested, reasonably reliable detection exists
Validated	The detection has been confirmed against an actual red team/purple team exercise

Purple Teaming with ATT&CK

8.1 What purple teaming adds

A red team exercise alone tells you whether an attack succeeded. Purple teaming pairs the red team's execution with the blue team watching in real time, technique by technique, specifically to answer a narrower and more useful question: *was this technique detected, and if not, why not?*

8.2 A basic purple team workflow

- Select a small, specific set of techniques to test (not a full campaign)
- Red team executes each technique individually, in a controlled, logged sequence
- Blue team checks, technique by technique, whether an alert fired
- Any miss becomes a specific, scoped detection engineering task
- Re-test the same technique later to confirm the new detection actually works

Atomic testing

Tools like Atomic Red Team package individual ATT&CK techniques as small, self-contained test scripts — letting a team validate one specific technique's detection coverage in minutes, without needing a full red-team engagement to test a single gap.

8.3 Why this pairs naturally with Nmap and Wireshark

Many Enterprise techniques — discovery, lateral movement, C2 — are directly observable at the network layer. A purple team exercise testing T1046 (Network Service Discovery) might literally run an Nmap scan as the red-team action, while the blue team watches for it in Wireshark or a SIEM built from the earlier playbooks in this series — the same skills, applied to a specific, named technique instead of a generic "watch the network."

The ATT&CK Navigator

9.1 What Navigator is

ATT&CK Navigator is a free, browser-based tool for visualizing the matrix as an interactive heat map — coloring individual techniques by whatever metric matters: detection coverage, a specific group’s known behavior, or gaps identified during a purple team exercise.

9.2 Common Navigator layers

Layer type	Shows
Detection coverage	Which techniques have detections, colored by confidence level
Group overlay	Every technique a specific threat group is known to use
Gap analysis	Techniques relevant to your threat model with no coverage at all
Campaign comparison	Overlapping techniques across two or more tracked groups

A practical starting workflow

Load a relevant group’s technique layer (based on real threat intel for your sector), overlay it against your own detection-coverage layer, and the resulting color differences are an instant, prioritized gap list — built directly from what’s actually likely to target you, not the full matrix at once.

Mapping Tools to ATT&CK

10.1 Nmap and reconnaissance/discovery techniques

ID	Technique	Nmap relevance
T1046	Network Service Discovery	Nmap's core function; also what defenders need to detect
T1018	Remote System Discovery	Host discovery / ping sweeps
T1595	Active Scanning	External-facing recon, before initial access

10.2 Wireshark and detection

ID	Technique	Wireshark relevance
T1071	Application Layer Protocol	C2 traffic analysis, covered in the Protocol Deep Dive chapter
T1041	Exfiltration Over C2 Channel	Large sustained transfers, covered in Recognizing Malicious Traffic
T1590	Gather Victim Network Information	Passive recon visible as unusual external scanning traffic

10.3 SIEM (Splunk/Wazuh) and broad coverage

The SIEM Playbook's entire detection engineering chapter is, in ATT&CK terms, a generalized version of what this chapter does per-tool: turning a data source into a technique-mapped detection, then tuning it based on real-world false positive rates.

The throughline across this whole series

Networking explains the substrate; Nmap and Wireshark give visibility into it; SIEM correlates that visibility at scale; ATT&CK is the vocabulary that ties every resulting detection back to a specific, named adversary behavior everyone else in the industry uses the same terms for.

Common Technique Walkthroughs

11.1 T1566 Phishing

- Sub-techniques cover spearphishing via attachment, link, and service (e.g. a compromised SaaS account)
- Detection: email gateway logs, URL/attachment sandboxing results, and user-reported phishing
- Downstream effect: almost always chains directly into T1204 (User Execution)

11.2 T1055 Process Injection

- Sub-techniques include DLL injection, process hollowing, and thread execution hijacking
- Detection: EDR-level API call monitoring is usually required; process/network correlation alone often misses it
- Common motivation: evade detections tied to the injecting process's own reputation

11.3 T1078 Valid Accounts

- Covers default, local, domain, and cloud accounts obtained legitimately or stolen
- Detection is behavioral, not signature-based: impossible travel, off-hours logons, unusual resource access for that account
- One of the hardest tactics to detect precisely because the activity looks like normal use by design

11.4 T1486 Data Encrypted for Impact

- The technique ID directly behind ransomware's final, destructive stage
- By the time this technique fires, most valuable detection opportunities were earlier in the chain — Initial Access through Lateral Movement
- Reinforces why full-chain coverage matters more than trying to catch the last, loudest step alone

Building a Threat-Informed Detection Roadmap

12.1 A practical prioritization approach

- Start from actual threat intel relevant to your sector, not the full 200+ technique matrix at once
- Cross-reference the resulting technique list against current detection coverage
- Prioritize techniques that chain early (Initial Access, Execution) — catching those prevents everything downstream
- Budget separate, ongoing time for validation — an untested detection is a coverage claim, not a working one

12.2 A repeatable quarterly cycle

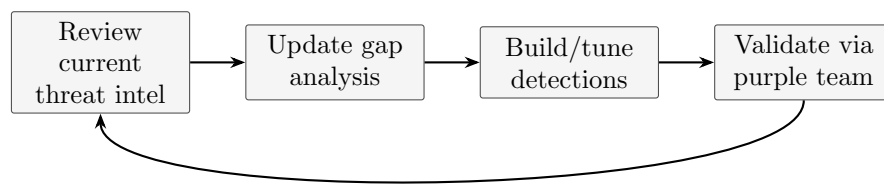


Figure 12.1. *A detection program built this way stays current instead of freezing around whatever threats mattered the year it was created.*

Where to go from here

Every earlier playbook in this series — networking fundamentals, Nmap, Wireshark, and the SIEM platforms — feeds directly into this roadmap. The tools produce the visibility; ATT&CK is what turns that visibility into a structured, prioritized, and measurable detection program instead of a loose pile of individually clever alerts.